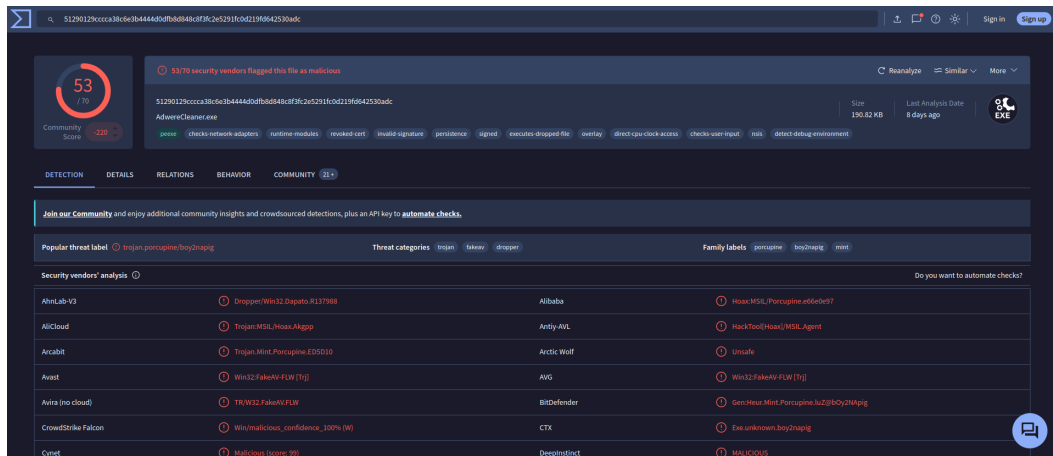


REPORT BW3

1- Analisi Malware



Il malware si chiama **AdwareCleaner.exe** è classificato come un 53/100 livello di pericolo e fa parte della famiglia dei Trojan.

Esercizio 2: Server Linux

```
CyberSecurity Lab VM Workstation 20230409 [In esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

File Edit View Search Terminal Help
[analyst@secops ~]$ sudo ps -ejh
[sudo] password for analyst:
  952   1864   1864   1864  tty7      0  0:59 /usr/lib/xorg
  1    1110   1110   1110  tty1      0  0:00 /sbin/agetty
 1718   2504   2504   1718  pts/0     0  0:00 sudo ps -ejh
 2504   2505   2505   2505  pts/1     0  0:00 sudo ps -ejh
 2505   2506   2506   2505  pts/1     0  0:00 ps -ejh COLOR
[analyst@secops ~]$ sudo ps /ejf
error: garbage option

Usage:
ps [options]

Try 'ps --help <single|list|output|threads|misc|all>'
or 'ps --help -c|l|o|t|n|a|'
for additional help text.

for more details see ps(1).
[analyst@secops ~]$ sudo ps -ejf
UID          PID    PPID    PGID     SID    C  TIME  TTY      TIME CMD
root         1        0      1        1  0  0:13:57 ?        00:00:02 /sbin/init s
root         2        0      0        0  0  0:13:57 ?        00:00:00 [kthreadd]
root         3        2      0        0  0  0:13:57 ?        00:00:00 [rcu_gp]
root         4        2      0        0  0  0:13:57 ?        00:00:00 [rcu_per_gp]
root         5        2      0        0  0  0:13:57 ?        00:00:00 [slub_flushw
root         6        2      0        0  0  0:13:57 ?        00:00:00 [netns]
root         8        2      0        0  0  0:13:57 ?        00:00:00 [worker/0:0
root        10        2      0        0  0  0:13:57 ?        00:00:00 [m_percpu_w
root        11        2      0        0  0  0:13:57 ?        00:00:00 [rcu_tasks_r
root        12        2      0        0  0  0:13:57 ?        00:00:00 [rcu_tasks_t
root        13        2      0        0  0  0:13:57 ?        00:00:00 [ksoftirqd/0
root        14        2      0        0  0  0:13:57 ?        00:00:01 [rcu_sched]
root        15        2      0        0  0  0:13:57 ?        00:00:00 [migration/0
root        16        2      0        0  0  0:13:57 ?        00:00:00 [idle_inject
root        18        2      0        0  0  0:13:57 ?        00:00:00 [cpuhp/0]
root        19        2      0        0  0  0:13:57 ?        00:00:00 [cpuhp/1]
root        20        2      0        0  0  0:13:57 ?        00:00:00 [idle_inject
root        21        2      0        0  0  0:13:57 ?        00:00:01 [migration/1
root        22        2      0        0  0  0:13:57 ?        00:00:01 [ksoftirqd/1
root        24        2      0        0  0  0:13:57 ?        00:00:00 [worker/1:0
root        25        2      0        0  0  0:13:57 ?        00:00:00 [kdevtmpfs]
root        26        2      0        0  0  0:13:57 ?        00:00:00 [inet_frag_w
root        27        2      0        0  0  0:13:57 ?        00:00:00 [kauditd]
root        28        2      0        0  0  0:13:57 ?        00:00:00 [khungtaskd]
root        29        2      0        0  0  0:13:57 ?        00:00:00 [oom_reaper]
root        30        2      0        0  0  0:13:57 ?        00:00:00 [writeback]
root        31        2      0        0  0  0:13:57 ?        00:00:00 [kcompactd0]
root        32        2      0        0  0  0:13:57 ?        00:00:00 [ksmd]
root        33        2      0        0  0  0:13:57 ?        00:00:00 [khugepaged]
```

Perché è stato necessario eseguire ps come root (premettendo il comando con sudo)?

Io ho dovuto eseguire ps come amministratore perchè io possa avere una visibilità totale e accesso alle informazioni /proc e mi dà l'albero completo di tutti i processi in esecuzione della macchina

Come viene la gerarchia dei processi ps?

l'output si presenterà organizzato in colonne rigide con una struttura ad albero rientrata.

```
[analyst@secOps ~]$ sudo netstat -tunap
[sudo] password for analyst:
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:21             0.0.0.0:*               LISTEN      938/vsftpd
tcp        0      0 0.0.0.0:22             0.0.0.0:*               LISTEN      1069/sshd: /usr/sbi
tcp        0      0 127.0.0.53:53          0.0.0.0:*               LISTEN      416/systemd-resolve
tcp6       0      0 :::23                  :::*                    LISTEN      1095/xinetd
tcp6       0      0 :::22                  :::*                    LISTEN      1069/sshd: /usr/sbi
udp        0      0 127.0.0.53:53          0.0.0.0:*               416/systemd-resolve
udp        0      0 192.168.1.21:68        0.0.0.0:*               369/systemd-network
udp        0      0 192.168.1.21:123       0.0.0.0:*               996/ntpd
udp        0      0 127.0.0.1:123          0.0.0.0:*               996/ntpd
udp        0      0 0.0.0.0:123            0.0.0.0:*               996/ntpd
udp6       0      0 fe80::a00:27ff:fe55:123 :::*                    996/ntpd
udp6       0      0 ::1:123                :::*                    996/ntpd
udp6       0      0 :::123                 :::*                    996/ntpd
[analyst@secOps ~]$
```

Qual è il significato delle opzioni -t, -u, -n, -a e -p in netstat?

-t è per mostra connessioni TCP, -u mostra connessioni UDP, -n connessioni IP e DNS, -a includi anche tutte le porte che sono semplicemente in stato di ascolto (**LISTENING**), pronte a ricevere connessioni. -p mostra il **PID** (Process ID) e il **nome del programma** o processo proprietario di quel determinato socket di rete.

L'ordine delle opzioni è importante per netstat?

No è particolarmente importante perchè li puoi mettere in qualsiasi ordine.

Basandosi sull'output di netstat mostrato al punto (d), qual è il protocollo di Livello 4, lo stato della connessione e il PID del processo in esecuzione sulla porta 80?

Il protocollo usato LV4 è Tcp/Udp

Sebbene i numeri di porta siano solo una convenzione, puoi indovinare che tipo di servizio è in esecuzione sulla porta 80 TCP?

Systemd-network

Esercizio 3: Navigare nel Filesystem Linux e Impostazioni dei Permessi

```
analyst@secOps ~]$ cd /
analyst@secOps /]$ ls -l
total 2097224
lrwxrwxrwx 1 root root 7 Aug 9 2022 bin -> usr/bin
drwxr-xr-x 3 root root 4096 Feb 10 2023 boot
drwxr-xr-x 17 root root 4020 Jun 22 13:58 dev
drwxr-xr-x 131 root root 12288 Jun 16 14:43 etc
drwxr-xr-x 9 root root 4096 Jun 16 14:43 home
lrwxrwxrwx 1 root root 7 Aug 9 2022 lib -> usr/lib
lrwxrwxrwx 1 root root 9 Aug 9 2022 lib32 -> usr/lib32
lrwxrwxrwx 1 root root 9 Aug 9 2022 lib64 -> usr/lib64
lrwxrwxrwx 1 root root 10 Aug 9 2022 libx32 -> usr/libx32
drwx----- 2 root root 16384 Feb 10 2023 lost+found
drwxr-xr-x 2 root root 4096 Aug 9 2022 media
drwxr-xr-x 2 root root 4096 Aug 9 2022 mnt
drwxr-xr-x 3 root root 4096 Apr 9 2025 opt
dr-xr-xr-x 209 root root 0 Jun 22 15:57 proc
drwx----- 5 root root 4096 Jun 18 13:58 root
drwxr-xr-x 29 root root 840 Jun 22 15:15 run
lrwxrwxrwx 1 root root 8 Aug 9 2022 sbin -> usr/sbin
drwxr-xr-x 4 root root 4096 Feb 10 2023 srv
-rw----- 1 root root 2147483648 Feb 10 2023 swap.img
dr-xr-xr-x 13 root root 0 Jun 22 15:57 sys
drwxrwxrwt 12 root root 4096 Jun 22 16:27 tmp
drwxr-xr-x 14 root root 4096 Jan 31 2023 usr
drwxr-xr-x 13 root root 4096 Feb 10 2023 var
analyst@secOps /]$
```

Qual è il significato dell'output?

ls -l mostra il contenuto per esteso all'interno della cartella

Dove sono fisicamente memorizzati i file elencati?

Nella directory usr/lib

Perché /dev/sdb1 non viene mostrato nell'output sopra?

Perché è un file nascosto e per scoprirlo bisogna avviare ls -a

```
Terminal
File Edit View Search Terminal Help
[analyst@secops ~]$ cd lab.support.files/scripts
[analyst@secops scripts]$ ls -l
total 64
-rwxr-xr-x 1 analyst analyst 1192 Jan 15 2023 configure_as_dhcp.sh
-rwxr-xr-x 1 analyst analyst 1499 Jan 15 2023 configure_as_static.sh
-rwxr-xr-x 1 analyst analyst 3459 Jan 13 2023 cyberops_extended_topo_no_fw.py
-rwxr-xr-x 1 analyst analyst 4062 Jan 13 2023 cyberops_extended_topo.py
-rwxr-xr-x 1 analyst analyst 3671 Jan 12 2023 cyberops_topo.py
-rw-r--r-- 1 analyst analyst 2871 Jan 12 2023 cyops.mn
-rwxr-xr-x 1 analyst analyst 458 Jan 12 2023 fw.rules
-rw-r--r-- 1 analyst analyst 3004 Jan 31 2023 mal_server.conf
-rwxr-xr-x 1 analyst analyst 110 Jan 13 2023 mal_server_start.sh
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 net_configuration_files
-rwxr-xr-x 1 analyst analyst 71 Jan 13 2023 reg_server_start.sh
-rwxr-xr-x 1 analyst analyst 189 Jan 12 2023 start_ELK.sh
-rwxr-xr-x 1 analyst analyst 91 Jan 13 2023 start_minidtt.sh
-rwxr-xr-x 1 analyst analyst 76 Jan 12 2023 start_pox.sh
-rwxr-xr-x 1 analyst analyst 106 Jan 12 2023 start_snort.sh
-rwxr-xr-x 1 analyst analyst 87 Jan 31 2023 start_tftpd.sh
[analyst@secops scripts]$ touch /mnt/myNewFile.txt
touch: cannot touch '/mnt/myNewFile.txt': Permission denied
[analyst@secops scripts]$ ls -ld /mnt
drwxr-xr-x 2 root root 4096 Aug 9 2022 /mnt
[analyst@secops scripts]$ sudo mount /dev/sdb1 ~/second_drive/
[sudo] password for analyst:
[analyst@secops scripts]$ ls /l
ls: cannot access '/l': No such file or directory
[analyst@secops scripts]$ ls -l
total 64
-rwxr-xr-x 1 analyst analyst 1192 Jan 15 2023 configure_as_dhcp.sh
-rwxr-xr-x 1 analyst analyst 1499 Jan 15 2023 configure_as_static.sh
-rwxr-xr-x 1 analyst analyst 3459 Jan 13 2023 cyberops_extended_topo_no_fw.py
-rwxr-xr-x 1 analyst analyst 4062 Jan 13 2023 cyberops_extended_topo.py
-rwxr-xr-x 1 analyst analyst 3671 Jan 12 2023 cyberops_topo.py
-rw-r--r-- 1 analyst analyst 2871 Jan 12 2023 cyops.mn
-rwxr-xr-x 1 analyst analyst 458 Jan 12 2023 fw.rules
-rw-r--r-- 1 analyst analyst 3004 Jan 31 2023 mal_server.conf
-rwxr-xr-x 1 analyst analyst 110 Jan 13 2023 mal_server_start.sh
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 net_configuration_files
-rwxr-xr-x 1 analyst analyst 71 Jan 13 2023 reg_server_start.sh
-rwxr-xr-x 1 analyst analyst 189 Jan 12 2023 start_ELK.sh
-rwxr-xr-x 1 analyst analyst 91 Jan 13 2023 start_minidtt.sh
-rwxr-xr-x 1 analyst analyst 76 Jan 12 2023 start_pox.sh
-rwxr-xr-x 1 analyst analyst 106 Jan 12 2023 start_snort.sh
-rwxr-xr-x 1 analyst analyst 87 Jan 31 2023 start_tftpd.sh
[analyst@secops scripts]$ chmod myFiles.txt
chmod: missing operand after 'myFiles.txt'
```

Considera il file cyops.mn come esempio. Chi è il proprietario del file?

analyst

E il gruppo?

analyst

I permessi per cyops.mn sono -rw-r-r-. Cosa significa?

rappresenta i **permessi di accesso** di un file. È la risposta testuale che vedi nella prima colonna quando lanci il comando

Perché il file non è stato creato? Elenca i permessi, la proprietà e il contenuto della directory /mnt e spiega cosa è successo. Con l'aggiunta dell'opzione -d, elenca i permessi della directory genitore.

Registra la risposta nelle righe sottostanti.

Succede che di default il file non è possibile accedere senza il permesso. In aggiunta la -d mi mostra la directory e i permessi che c'ha.

```

Terminal
File Edit View Search Terminal Help
[analyst@secOps scripts]$ cd /home/analyst/lab.support.files
[analyst@secOps lab.support.files]$ ls -l
total 584
-rw-r--r-- 1 analyst analyst 649 Jan 12 2023 apache_in_epoch.log
-rw-r--r-- 1 analyst analyst 126 Jan 12 2023 applicationX_in_epoch.log
drwxr-xr-x 4 analyst analyst 4096 Jan 12 2023 attack_scripts
-rw-r--r-- 1 analyst analyst 102 Jan 12 2023 confidential.txt
-rw-r--r-- 1 analyst analyst 2871 Jan 12 2023 cyops.mn
-rw-r--r-- 1 analyst analyst 75 Jan 12 2023 elk_services
-rw-r--r-- 1 analyst analyst 373 Jan 12 2023 h2_dropbear.banner
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 instructor
-rw-r--r-- 1 analyst analyst 255 Jan 12 2023 letter_to_grandma.txt
-rw-r--r-- 1 analyst analyst 24464 Jan 12 2023 logstash-tutorial.log
-rwxr-x-- 1 analyst analyst 486 Jan 12 2023 long_commands
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 malware
-rwxr-xr-x 1 analyst analyst 172 Jan 12 2023 mininet_services
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 openssl_lab
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 pcaps
drwxrwxr-x 7 analyst analyst 4096 Jan 14 2023 pox
-rw-r--r-- 1 analyst analyst 473363 Jan 12 2023 sample.ing
-rw-r--r-- 1 analyst analyst 65 Jan 12 2023 sample.ing_SHA256.sig
drwxr-xr-x 3 analyst analyst 4096 Jan 31 2023 scripts
-rw-r--r-- 1 analyst analyst 25553 Jan 12 2023 SQL_Lab.pcap
[analyst@secOps lab.support.files]$

```

Qual è la differenza tra la parte iniziale della riga di malware e la riga di mininet_services?
Le differenze sono:

Elemento	Tipo	Permesso Proprietario	Permess o Altri	Dimensi one	Significato della x
malware	Direct ory	Leggi/Scrivi/E ntra	Solo Leggi/Entr a	4096 Byte	Permette di entrare nella cartella
mininet_services	File	Leggi/Scrivi/E segui	Solo Leggi/Ese gui	172 Byte	Permette di avviare lo script

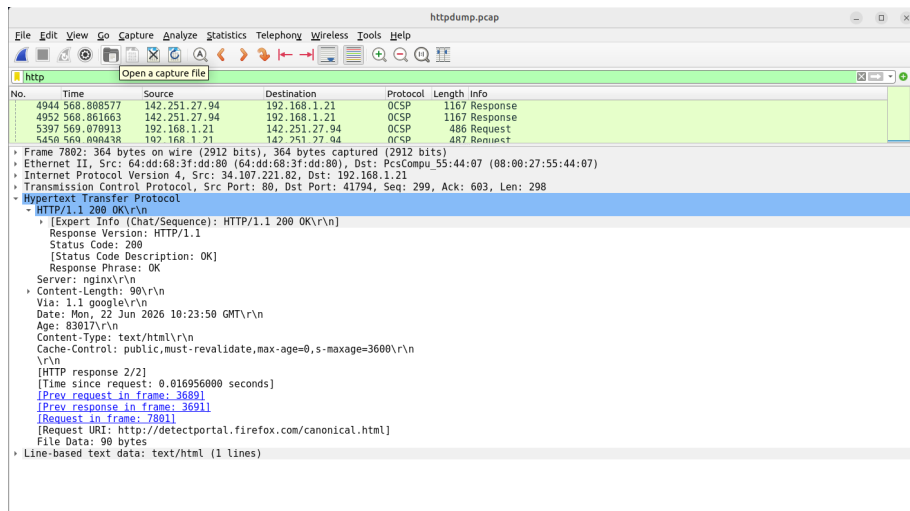
```

[analyst@secOps lab.support.files]$ echo "symbolic" > file1.txt
[analyst@secOps lab.support.files]$ cat file1.txt
symbolic
[analyst@secOps lab.support.files]$ echo "hard" > file2.txt
[analyst@secOps lab.support.files]$ cat file2.txt
hard
[analyst@secOps lab.support.files]$ ln -s file1.txt file1symbolic
[analyst@secOps lab.support.files]$ ln file2.txt file2hard
[analyst@secOps lab.support.files]$ ls -l
total 596
-rw-r--r-- 1 analyst analyst 649 Jan 12 2023 apache_in_epoch.log
-rw-r--r-- 1 analyst analyst 126 Jan 12 2023 applicationX_in_epoch.log
drwxr-xr-x 4 analyst analyst 4096 Jan 12 2023 attack_scripts
-rw-r--r-- 1 analyst analyst 102 Jan 12 2023 confidential.txt
-rw-r--r-- 1 analyst analyst 2871 Jan 12 2023 cyops.mn
-rw-r--r-- 1 analyst analyst 75 Jan 12 2023 elk_services
lrwxrwxrwx 1 analyst analyst 9 Jun 23 08:38 file1symbolic -> file1.txt
-rw-rw-r-- 1 analyst analyst 9 Jun 23 08:37 file1.txt
-rw-rw-r-- 2 analyst analyst 5 Jun 23 08:37 file2hard
-rw-rw-r-- 2 analyst analyst 5 Jun 23 08:37 file2.txt
-rw-r--r-- 1 analyst analyst 373 Jan 12 2023 h2_dropbear.banner
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 instructor
-rw-r--r-- 1 analyst analyst 255 Jan 12 2023 letter_to_grandma.txt
-rw-r--r-- 1 analyst analyst 24464 Jan 12 2023 logstash-tutorial.log
-rwxr-x-- 1 analyst analyst 486 Jan 12 2023 long_commands
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 malware
-rwxr-xr-x 1 analyst analyst 172 Jan 12 2023 mininet_services
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 openssl_lab
drwxr-xr-x 2 analyst analyst 4096 Jan 12 2023 pcaps
drwxrwxr-x 7 analyst analyst 4096 Jan 14 2023 pox
-rw-r--r-- 1 analyst analyst 473363 Jan 12 2023 sample.img
-rw-r--r-- 1 analyst analyst 65 Jan 12 2023 sample.img_SHA256.stg
drwxr-xr-x 3 analyst analyst 4096 Jan 31 2023 scripts
-rw-r--r-- 1 analyst analyst 25553 Jan 12 2023 SQL_Lab.pcap
[analyst@secOps lab.support.files]$ mv file1.txt file1new.txt
[analyst@secOps lab.support.files]$ mv file2.txt file2new.txt
[analyst@secOps lab.support.files]$ cat file1symbolic
cat: file1symbolic: No such file or directory
[analyst@secOps lab.support.files]$ cat file2hard
hard
[analyst@secOps lab.support.files]$

```

Cosa pensi succederebbe a file2hard se aprissi un editor di testo e cambiassi il testo in file2new.txt?
file2.txt è stato sostituito co file2new.txt

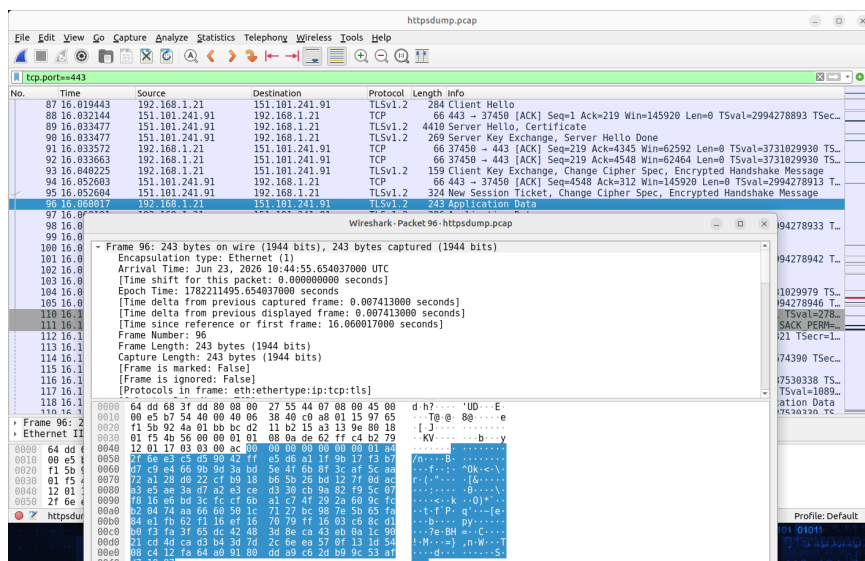
Esercizio 4: Usare Wireshark per Esaminare il Traffico HTTP e HTTPS



Quali due informazioni vengono visualizzate?

Se guardi all'interno dei dettagli dell'**Hypertext Transfer Protocol (HTTP)** espansi al centro dello schermo, balza subito all'occhio l'intestazione del server:

Server: nginx\r\nQuesto ci conferma che il server web remoto che ha generato questa risposta sta usando proprio **Nginx** come Web Server o come Reverse Proxy



Cosa ha sostituito la sezione HTTP che era nel file di cattura precedente?

Il protocollo che invece è TLSv1.2

I dati dell'applicazione sono in formato plaintext o leggibile?

Plaintext

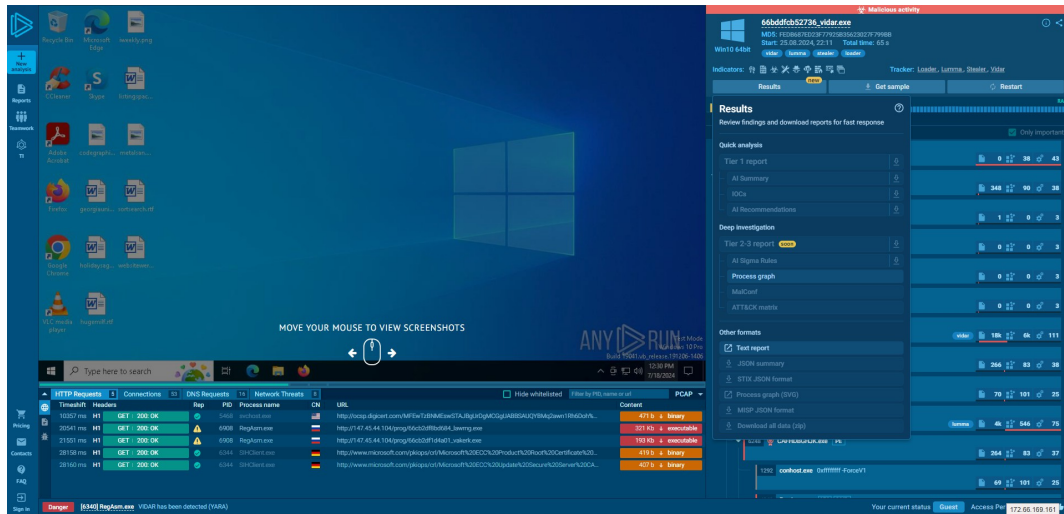
Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

Il primo è sicuro l'altro no

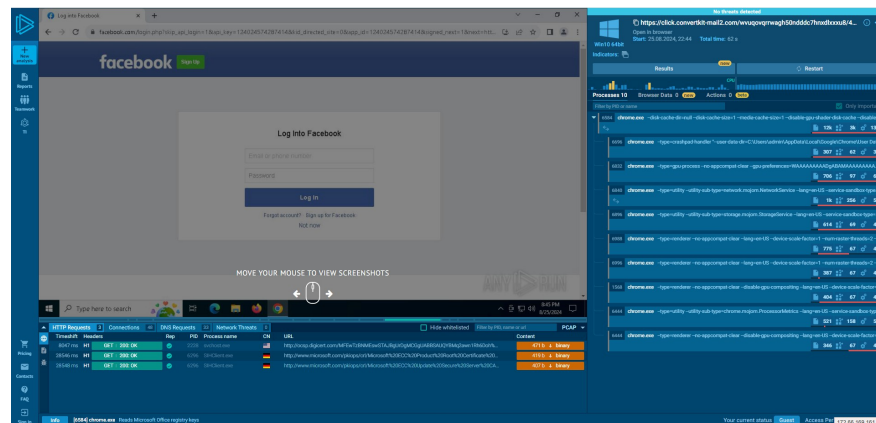
Tutti i siti web che usano HTTPS sono considerati affidabili?

Per la maggior parte si

Esercizio 5: Anyrun

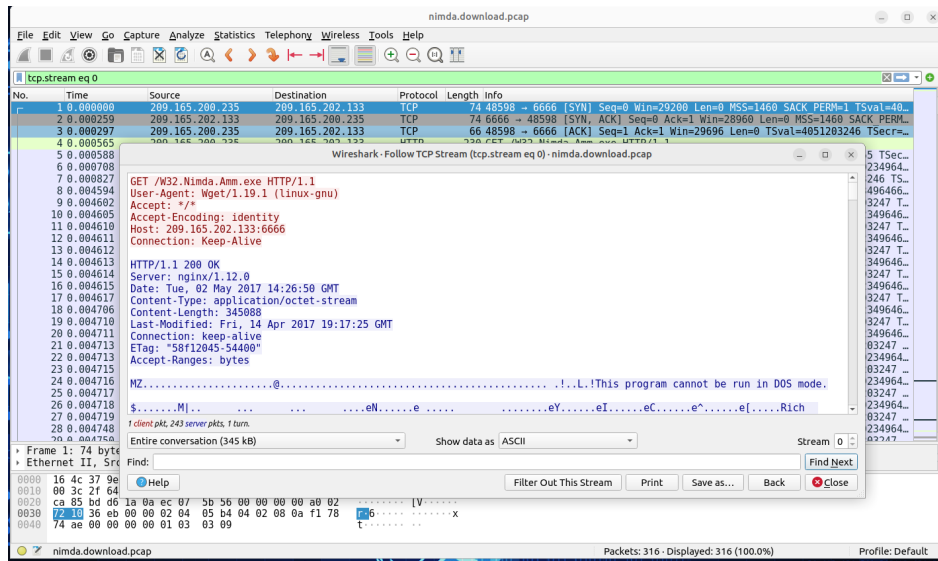


Il file 66bddfcb52736_vidar.exe praticamente è stato rilevato come malevolo
il malware è un eseguibile .exe ed è stato installato sul sistema



E' un semplice login accedere a Instagram con l'account facebook

Esercizio 6: Estrarre un Eseguibile da un PCAP



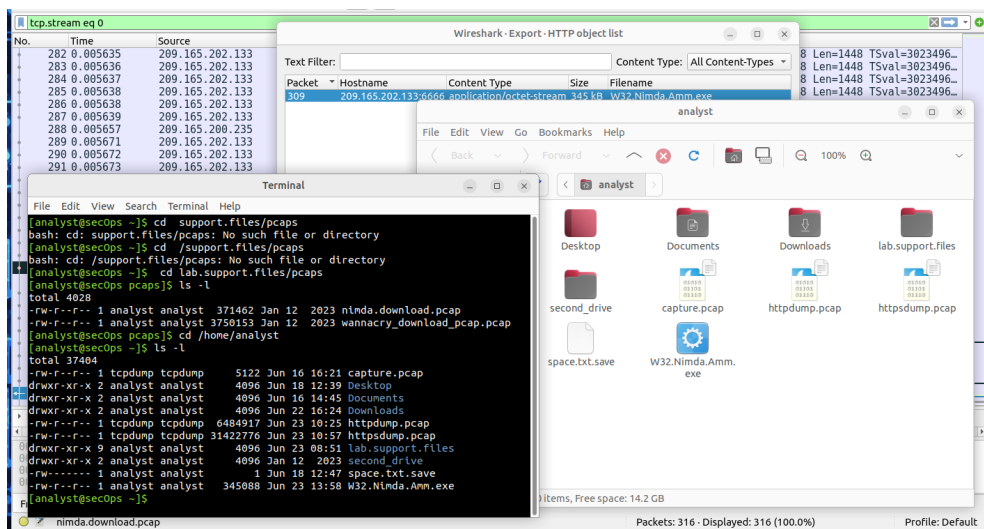
Cosa sono tutti quei simboli mostrati nella finestra Follow TCP Stream? Sono rumore di connessione? Dati? Spiega. Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì? Domanda Sfida: Nonostante il nome W32.Nimda.Amm.exe, questo eseguibile non è il famoso worm. Per motivi di sicurezza, questo è un altro file eseguibile che è stato rinominato come W32.Nimda.Amm.exe. Usando i frammenti di parole visualizzati dalla finestra Follow TCP Stream di Wireshark, puoi dire quale eseguibile sia realmente?

I simboli incomprensibili e i frammenti di parole che vedi nella schermata **Follow TCP Stream** di Wireshark rivelano la reale natura dei file e delle connessioni di rete.

No, non sono rumore di connessione. Quei simboli sono i **dati effettivi** del file che è stato trasferito sulla rete, ma visualizzati nel formato sbagliato.

Quando usi *Follow TCP Stream*, Wireshark cerca di interpretare e mostrare l'intero flusso di byte come se fosse un testo leggibile (caratteri ASCII o UTF-8).

Sebbene nel laboratorio Cisco CyberOps il file venga scaricato con il nome ingannevole di `W32.Nimda.Amm.exe` per simulare un vecchio e pericoloso worm, analizzando il flusso TCP e scorrendo fino in fondo tra le stringhe di testo leggibili incorporate nei simboli binari, si scopre l'identità del file. L'eseguibile nascosto è in realtà il prompt dei comandi di Windows: **`cmd.exe`**. Per ragioni di sicurezza nei laboratori didattici, non viene mai fatto scaricare del malware reale attivo; viene invece utilizzato un tool nativo e innocuo di Windows (in questo caso l'eseguibile di `cmd.exe`) rinominandolo semplicemente con il nome della firma del malware, così da innescare gli alert dei sistemi IDS (come Snort) senza mettere a rischio l'infrastruttura.



Perché W32.Nimda.Amm.exe è l'unico file nella cattura?

Perché è l'unico ad essere rilevato

Il file è stato salvato?

Sì

Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

Analizzare il file .exe su anyrun o virustotal